

INCIDENT RESPONSE PLAYBOOK

Playbook name	Suspected SQL Injection & API intrusion
Version	1.0
Author	Anna-Kayli Bradley
Date	27MAY25
Triggers	HTTP 400/500 spikes, repeated login attempts, admin access probing, API enumeration, possible data exposure
Expected driving time	60min triage, 72 hours for compliance-ready investigation
Seriousness rate	High

1. Purpose

This playbook defines the operational and communication procedures used by QuickSilver Materials during suspected SQL injection attack and API intrusion.

2. Incident Classification

2.1 Alert thresholds

The playbook lists the following behaviours as cause for alarm:

- multiple HTTP 400 and 500 alerts generated by the allocated SIEM agent
- repetitive failed login attempts
- repetitive attempts to access privileged account (i.e. admin, administrator, manager etc.)
- abnormal interaction with multiple APIs of non-standard nature
- access to customer's private and financial data
- access to individual private data
- multi-day actions that look similar in approach and scope of access
- above average ratio of login attempts to login success (HTTP 200) to privileged accounts during 24 hrs

2.2 Compliance

If customer or financial data may have been exposed, the incident must immediately be escalated for:

- NIS2 reporting assessment
- GDPR breach assessment
- executive review

3. Roles and Responsibilities

3.1 Points of contacts

Should security alert be raised the following persons must be contacted immediately

Function	Name	Daytime telephone	E-mail
CEO	Oleg Olegov	07545468048	oleg@qsmaterials.com
Incident Commander (IC)	Rob Robson	07165648456	rob@qsmaterials.com
Deputy Commander (DC)	Axel Axelsson	07235848451	axel@qsmaterials.com
Scribe	Gregory McGregg	07546554845	gregory@qsmaterials.com
Technical Lead	Russel Rousel	07156484565	russel@qsmaterials.com
Liaison	Carrie Carr	07953168451	carrie@qsmaterials.com

3.1 Role description

Incident Commander (IC)

- leadership and responsibility for handling and active-decision making during an incident
- team role assignment, task delegation and in-group coordination
- liaison and communication with CEO in real time
- providing effective framework and during an incident

- allocation and oversight over resources and methods used during an incident towards effective recovery
- communication with liaison person re: the incident and it's public handling
- make police report

Deputy Commander (DC)

- providing active assistance to IC as per need
- address missed decision points and issues to IC
- monitor status of the incident and inform IC of any changes

Scribe

- record relevant calls in real time
- make status reports in reference to the incident
- make attendance list of everyone in the response team
- keep a thorough eye on updates and include them in the notes in the order of appearance
- send reports to executives and authorities in the required time frame compliant with legal requirements

Technical Lead

- provide main technical reference point
- SIEM in-depth alert investigation
- multi-source alert and log correlation
- pattern recognition and IOC identification
- API and HTTP traffic review
- containment actions
- reporting findings to IC in adequate time

Liaison/ spokesperson

- protecting company's integrity during the incident as well as overseeing legal compliance during the response and investigation proceedings
- GDPR, NIST and relevant compliance assessment
- privacy impact evaluation
- coordination of the incident response to take place according to the legal requirements
- documentation of notification obligations
- coordination with media and PR teams to provide clean picture of the events to the public in accordance with relevant law and confidentiality
- issues communication to non-technical personnel re: incident and handling measures upon consultation with the IC

4. Communication Procedures

4.1 Internal Communication

During the incident:

- operational communication must occur through dedicated incident channels [list company's software used]
- all participants must be authenticated and verified regardless of their role before participating in the call
- Incident Commander takes charge for initiating the call and delegating tasks during proceedings
- all findings are to be communicated to Incident Commander in real time
- no issues, with no regard to perceived severity, are to remain unflagged without prior consulting with the Incident Commander
- all updates must be issued with no more than 15-minute interval
- no technical person communicates externally without IC's approval

4.2 Out-of-Band Communication

When compromise is confirmed:

- communication is to be outsourced to independent encrypted communication channel
- delegated software must be always set up and ready for such occasion ahead of the incident
- all communication going through official channels owned by the company or third party software configured for the company's communication needs, included but not limited to apps, e-mails, messaging system, intranet etc. is to be suspended during the duration of the investigation

- approved emergency communication channels are accessible through the following systems:

email: tutanota.io

internal communication: Signal

external and client communication: designated Signal channels. Telephone

5. Detection and Initial Triage

5.1 Investigation Indicators

- repeated requests against high value APIs, included but not limited to:

/rest/user/login

/rest/user/whoami

/api/Cards

/api/Address

/rest/wallet/balance

/rest/login/admin

- excessive HTTP 400 and 500 errors

- repeated requests from the same IP

- repetitive and multiple login attempts

- API enumeration patterns

- admin-related API access attempts

5.2 Initial triage action

1. verify SIEM alerts

2. review container access logs and error log

2a) if errors present review relevance and proceed to eradication as necessary

2b) if no errors present proceed to point 3 directly

3. correlate timestamps and IP activity

if activity spans across multiple days treat the activity as coordinated rather than isolated

4. identify affected containers and endpoints

5. determine whether unauthorized access occurred

if authentication succeeds after repeated failed attempts flag for possible abuse

6. determine whether sensitive data was viewed, used or extracted

if customer or financial data is involved escalate immediately to Incident Commander

7. confirm if a GDPR breach might've occurred and report your findings immediately to your supervisor

6. Investigation Procedures

The Technical Lead outlay:

- correlation of SIEM and raw access logs

- review of HTTP request patterns both from SIEM alerts and raw logs

- spotting authentication anomalies and forming a behavioural pattern

- detection of enumeration behaviour via API access

- inspection of all containers

- preservation of forensic artefacts the following order: download → timestamp → hash → record details → backup

Repeat each time an artifact has been added to database or modified

- review of accessed customer data

- reconstruction of attack timeline

- documentation of all findings on regular basis

When logs risk being overwritten, evidence preservation takes priority before containment actions are initiated.

When direct payload visibility is unavailable, behavioural analysis through HTTP patterns, timestamps and API access chronology must be used instead.

7. Containment Actions

7.1 Containment measures

Depending on severity, the following containment measures may be implemented:

- deployment of emergency protocols
- isolation of affected containers
- blocking suspicious IPs
- temporary restriction of admin APIs, relocation of admin to temporary accounts
- increased monitoring of SIEM alerts
- credential and access token resets
- sensitive API redesign to maintain public inaccessibility
- isolating and securing sensitive information that belong to affected 3rd parties
- communication with affected 3rd parties (listed but not limited to: clients, partners, customers, shareholders, employees, sensitive accounts holders etc.)
- PR control and media communication pertaining to the incident handled with integrity, honesty while confidential of the private data as well as the details pertaining to the investigation

7.2 Considerations

- if attacker activity is ongoing containment takes priority over investigation
- if evidence has not yet been preserved affected containers are not to be restarted or otherwise modified
- if privileged access is confirmed all active sessions and authentication tokens must be invalidated immediately
- if compromise of internal communication channels is suspected all strategic communication must immediately transition to approved out-of-band channels

7.3 Integrity preservation

Containment actions must take into account:

- preservation operational continuity
- evidence preservation takes precedence before any containment actions not to avoid loss of data.
- prevention of continued unauthorized access
- secrecy of the investigation process from uninvolved parties

8. Escalation and Reporting

8.1 24-Hour Warning Threshold

If suspicious activity indicates potential compromise of critical web services or sensitive information leak as a result of a breach, the Incident Commander initiates:

- internal escalation
- executive notification
- preparation of 24-hour warning report

8.2 72-Hour Notification Threshold

If the investigation confirms:

- unauthorised access
 - potential personal data exposure and/or extraction
 - compromise of the company's web services
- then the incident is escalated under the following legal benchmarks
- NIS2
 - GDPR

When exposure of personal or financial information cannot be ruled out, notification preparation begins immediately even if the full technical scope is still under investigation.

9. Recovery Procedures

Recovery actions include as per case:

- API hardening
- implementation of parameterised queries
- improved input validation
- privilege separation enforcement
- expanded forensic logging and access
- implementation of stricter SIEM rules
- authentication monitoring enhancements

Services are only returned to normal operation after:

- verification of containment
- improvement and validation of system integrity
- review of previously-affected assets
- approval by Incident Commander

10. Post-Incident Review

Following closure of the incident:

- a full timeline is constructed
- effectiveness is evaluated
- detection gaps are identified and addressed
- logging deficiencies are handled
- recommendations are implemented into future incident-handling

10. Common pitfalls

A major risk during an active incident is focusing too much on visible SIEM alerts while missing the wider context of the attack. In this scenario, repeated HTTP 400 and 500 alerts could easily be dismissed as unstable web behaviour or normal errors if analysts only superficially viewed alerts without looking into the raw data carrying significant information load: timestamps, targeted APIs, login behaviour, and follow-up access to customer information.

Another critical pitfall is using compromised communication channels upon suspected breach. If the attacker gains access to the company's internal comm like e-mail, apps, intranet etc. communication no more flows within company's integrity bounds which creates risk that the decisions, findings or recovery measures become visible to the attacker.